Cẩm nang AutoSpy

1) Chiến lược tối ưu hóa khi Add Data Source

Cấu hình tối ưu khi Ingest (tick các mục sau):

- **File Type Identification:** Bắt buộc (để xác định đúng định dạng file, tránh việc tác giả đổi đuôi file như .jpg thành .txt).
- **Extension Mismatch Detector :** Phát hiện các file bị cố tình đổi đuôi.
- **Keyword Search:** Tắt tìm kiếm toàn bộ (Solr) , chỉ nên dùng tính năng tìm kiếm thủ công bằng Regex sau khi load xong để tìm flag
- **Recent Activity**: Module này sẽ cào sạch lịch sử trình duyệt, cookies , download , các file mở gần đây , và registry.
- **Encryption Detection**: Để kiểm tra xem có file nào bị mã hóa bằng BitLocker , VeraCrypt , hoặc file zip có pass.

2) Các tọa độ để khai thác Flag

Với Web History và Web Articfacts :

- Web history và Search Queries : Xem user đã tải file gì , truy cập vào link độc hại nào , hoặc đã dùng các payload gì trên các trang web(VD: các payload SQLi, XSS, Command Injection thường lộ rõ trên URL trong lịch sử web).
- Web cookies / Form Autocomplete: Nơi chứa Session ID , Token , hoặc mật khẩu được admin lưu sẵn.
- Web Downloads : Tìm các script , file shell (.php , .asp , .py) mà attacker đã tải lên hoặc tải về máy nạn nhân.

Với OS/System Activity (Dấu vết thực thi) :

- Run Programs (Prefetch / Shimcache / BAM): Cho biết chính xác attacker đã chạy công cụ gì (ví dụ : sqlmap , nmap , nc)
- Recent Documents: Các file mật , đề bài , flag thường nằm trong danh sách các file mở gần đây của user.
- Shell Bags: Cho biết user đã từng truy cập vào những folder nào (ngay cả khi folder đó đã bị xóa)

3) Tính năng nâng cao của AutoSpy

Tìm kiếm Flag bằng Regular Expression (Regex) nâng cao

Thay vì index toàn bộ ổ đĩa , vào mục Keyword search (Góc trên cùng bên phải) , chọn Regular Expression:

- Tìm Flag format chung: Flag{...} hoặc CTF{...} (Tùy thuộc vào format giải đấu
- Tìm kiếm dấu vết web exploitation (IP , URL , Email):
  + IP address: \b\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3}\b

+Dấu vết Webshell hoặc Payload nguy hiểm: eval\(, system\(, passthru\(, base64_decode\(

Khôi phục các file bị xóa (Deleted Files)

Tác giả rất thích giấu flag trong các file đã bị xóa (Unallocated space hoặc Recycle Bin):

- Nhìn xuống nhánh File views , Deleted Files
- Autospy sẽ gom toàn bộ các file có flag "deleted" lại một chỗ. Check cả mục All và FileSystem để xem cấu trúc thư mục cũ của file đó.
- Nếu file bị mất cả metadata (nằm trong Unallocated Space) , dùng tính năng PhotoRec Ingest Module tích hợp sẵn trong Autospy để "carving" (Khôi phục file dựa trên file signature/magic bytes)

Trích xuất và phân tích file cụ thể (Extract Artifacts):

Khi tìm thấy một file nghi vấn (ví dụ .zip khóa pass , file pcap log mạng , hoặc file source code web .php nằm trong thư mục cài đặt Apache/Nginx): Click chuột vào file , ấn Extract File để đứa ra ngoài máy thật rồi dùng các công cụ chuyên dụng khác xử lý như (hashcat , wireshark , john the ripper).